Ce qu'il ne faut pas faire

- Entamer la prestation de sous-traitance sans avoir signé avec le prestataire un contrat reprenant les exigences posées par l'article 28 du RGPD.
- Avoir recours à des services de *cloud* sans garantie quant à la localisation géographique effective des données et sans s'assurer des conditions légales et des éventuelles formalités pour les transferts de données en dehors de l'Union européenne.

POUR ALLER PLUS LOIN

- La CNIL a publié un guide à destination des sous-traitants[64].
- Consulter et mettre en œuvre les dispositions de l'article 28 du RGPD.
- Apporter une attention particulière au choix d'un fournisseur de service *cloud* (voir la fiche n°22 - *Cloud* : Informatique en nuage).
- Toute la chaine de sous-traitance (sous-traitants des sous-traitants) devrait être considérée et non seulement les sous-traitants directs.
- Lors du choix d'un sous-traitant, l'obtention d'une certification est un premier indice pour évaluer sa fiabilité. Par exemple, la norme internationale ISO/IEC 27001 impose des mesures organisationnelles et techniques pour la mise en place d'un système de management de la sécurité de l'information (SMSI), tandis que la norme ISO/IEC 27701[65] concerne le système de management de la protection de la vie privée (PIMS en anglais).
- Concernant les données de santé, un hébergeur doit disposer d'une certification d'hébergeur de données de santé (HDS)[66]. L'Agence du numérique en santé (ANS) publie la liste des hébergeurs certifiés[67]. À noter que la certification a progressivement remplacé l'agrément HDS depuis 2018 et que certains hébergeurs disposent encore d'un agrément[68] valide.
- Le cas échéant, exiger la communication par le prestataire de ses certifications et en vérifier le périmètre.

64 « Règlement européen sur la protection des données : un guide pour accompagner les sous-traitants », cnil.fr

65 « L'ISO 27701, une norme internationale pour la protection des données personnelles », cnil.fr

66 « HDS - Certification Hébergeur de Données de Santé », esante.gouv.fr

67 « Liste des hébergeurs certifiés », esante.gouv.fr

68 « Liste des hébergeurs agréés », esante.gouv.fr